

NIS2 Incident Playbook

Reporting for a small WordPress agency or freelancer. Keep it off the server it protects.

LAW = required by NIS2 when your client is in scope · **PRACTICE** = my recommendation, not the directive.

BEFORE ANYTHING BREAKS · PRE-FLIGHT

☐ Incident lead: _____ backup: _____

☐ Playbook stored off-server **PRACTICE** where: _____

☐ Logs retained ≥ 90 days **PRACTICE** (Art. 21 asks for logging)

☐ Notification templates pre-filled with org data **PRACTICE**

☐ Contract clauses with regulated clients **LAW** (who notifies what, to whom, when, per Art. 21(2)(d))

THE CLOCK · FILL THE MOMENT YOU BECOME AWARE

Became aware (date / time): _____

+24h
Early warning due

+72h
Notification due

+30d
Final / progress due

STEP 1 · NOW Detect & triage
Detected via: monitoring / client ticket / host notice

Malicious cause suspected? ☐ Y ☐ N

Service seriously disrupted? (down for hours) ☐ Y ☐ N

Personal data exposed? ☐ Y ☐ N

Unauthorised access gained? ☐ Y ☐ N

*Any YES → bring it to the client. The regulated entity makes the call.
When in doubt, report.*

STEP 2 · 24h Early warning **LAW · ART. 23(4)(A)**
Sender: regulated entity → national CSIRT. Supply chain: notify your client in minutes, their clock starts when they know.

Malicious cause ☐ Y ☐ N ☐ ?

Cross-border impact ☐ Y ☐ N ☐ ?

Known impact (one line): _____

Contact + alternate: _____

☐ Client / CSIRT notified at: _____

It is an alert, not a confession. "Investigating" is a valid answer.

STEP 3 · 72h Notification **LAW · ART. 23(4)(B)**

☐ Severity assessment

☐ IoCs: IPs, file hashes, suspicious URLs

☐ Mitigations already applied

Authority may request an intermediate report any time before day 30. Be ready.

STEP 4 · PARALLEL Coordinate & protect

☐ Hosters: forensics, isolation, log preservation **PRACTICE**

☐ Upstream vendor: responsible disclosure if source **PRACTICE**

☐ Protect users when they can act **LAW · ART. 23(1)-(2)**

Change a password · rotate an API key · watch for phishing. Sender: the client. Technical content: you.

STEP 5 · 30d Final or progress **LAW · ART. 23(4)(D)**

☐ Closed → final report: root cause, timeline, mitigations, cross-border

☐ Ongoing → monthly progress until closed

☐ Feed back into playbook + risk register **PRACTICE**

KEY CONTACTS

National CSIRT: _____ *IT: ACN · FR: CERT-FR · PL: CSIRT NASK*

Regulated client: _____ Hosters: _____ Vendors: _____

Reporting is a **workflow**, not paperwork.

Francesco Canovi · Black Studio · @TheDarkMist